Informe Técnico de Respuesta a Incidentes:

Afectación por Dridex en Red Corporativa

PRÁCTICAS FPE:

ESTE DOCUMENTO ES UNA **SIMULACIÓN DE INFORME** NO EXPONE DATOS DE LA EMPRESA

Autor: Cristóbal Jesús Subires Macías

Hispasec]

1. Resumen ejecutivo.....2
2. Descripción del incidente.....2
2.1. Equipos y Activos Implicados.....3
2.2. Línea Cronológica.....3
3. Análisis Técnico.....4
4. Evidencias.....4
4.1 Indicadores de Compromiso (IOCs).....4
Archivo Malicioso extraído (pcap).....4
Direcciones IP Maliciosas.....6
4.2 Indicadores de Ataque (IoAs).....7
Análisis del volcado de tráfico (pcap).....7
Reglas de Alertas IDS.....8
5. Acciones realizadas.....9
5.1 Acciones de detección.....9
5.2 Acciones de contención.....9
5.3 Acciones de análisis.....9
5.4 Acciones de erradicación y recuperación.....9
6. Conclusión del incidente.....10
7. Recomendaciones.....11
Inmediatas.....11
A corto plazo.....11
A largo plazo.....12
Referencias y fuentes de información usadas.....12
Apéndice.....13

La elaboración de este informe se hizo mediante estrictas medidas de seguridad, en un entorno virtualizado desconectado de la red, los archivos generados en un sistema Linux a partir de las evidencias no se ejecutaron en ningún momento, los análisis realizados fueron de tipo estático y/o mediante herramientas online sin involucrar información confidencial.

*En caso de cualquier duda póngase en contacto con el autor de este informe o llame al **017** para recibir asesoramiento.*

https://www.incibe.es/linea-de-ayuda-en-ciberseguridad

1. Resumen ejecutivo

El 28 de enero de 2019 se detectó una infección por malware tipo troyano bancario en un equipo del dominio corporativo. La infección se produjo tras la descarga de un binario desde un servidor HTTP externo no habitual.

Se identificaron conexiones posteriores a infraestructura asociada a comando y control (C2), así como un acceso remoto vía RDP (Protocolo de escritorio remoto) desde una IP catalogada como maliciosa.

Existe riesgo potencial de movimiento lateral y compromiso del controlador de dominio. Actualmente el incidente se encuentra en fase de contención.

2. Descripción del incidente

El **28 de enero de 2019,** durante una revisión de seguridad rutinaria, se identificaron alertas del IDS que indican un incidente de seguridad ocurrido a las **21:49**, de forma automatizada nuestros sistemas generaron un volcado del tráfico que nos ha permitido saber más detalles. El incidente comenzó con la **descarga** de un binario malicioso desde un servidor remoto no confiable, identificado posteriormente como el **troyano bancario** Dridex.

El vector de infección inicial presuntamente fue un correo de **phishing**. El análisis determinó que el equipo afectado (172.17.8.109) se vio comprometido, permitiendo al atacante establecer una conexión de Escritorio Remoto (RDP) y, potencialmente, moverse lateralmente por la red. Esto representa un riesgo significativo de compromiso total del dominio.

Este informe detalla los hallazgos, las acciones de contención inmediatas y las recomendaciones para fortalecer la seguridad y evitar futuros incidentes.

2.1. Equipos y Activos Implicados

Nombre	Rol	Dirección IP	Dirección MAC	Observaciones
dunn-windows-pc	Víctima Inicial	**172.17.8.109**	14:FE:B5:D4:15:CA	Equipo Windows (Dell)
Servidor Remoto	Descarga de Malware	91.121.30.169	-	Puerto 8000 (HTTP)
Dirección Atacante	Conexión RDP	192.241.220.183	-	IP maliciosa conocida, puerto 3389
DC-TIMBERSHADE.INFO	Controlador de Dominio	172.17.8.2	00:21:5E:72:9E:B4	Windows Server (IBM). Potencial objetivo.
Servidor C2	Comando y Control	216.239.94.252	-	Conexiones HTTPS (443). Certificado SSL malicioso.

* máquinas atacantes

2.2. Línea Cronológica

Hora (aprox.)	Evento	Evidencia / Alerta de Seguridad
28/01/2019 21:49	Usuario ejecuta un binario malicioso descargado.	Conexión HTTP saliente desde 172.17.8.109 a 91.121.30.169:8000 para descargar actiV.bin (sospechoso por puerto no estándar).
28/01/2019 21:52	Atacante intenta acceder vía RDP al equipo víctima.	Conexión entrante RDP (puerto 3389) desde IP maliciosa externa a la red 192.241.220.183 a 172.17.8.109. Posible explotación de buffer overflow.
28/01/2019 21:55	El malware establece comunicación con su Centro de Mando y Control (C2).	Múltiples conexiones cifradas (HTTPS) desde la víctima a 216.239.94.252:443. Regla: *ET TROJAN ABUSE.CH SSL Blacklist Malicious SSL certificate detected (Dridex)*.

3. Análisis Técnico

El análisis del binario *actiV.bin* (SHA256: 9f6e3e65...) confirma que se trata de una variante del troyano bancario Dridex. Este malware está diseñado para robar credenciales bancarias mediante técnicas de inyección en procesos legítimos del navegador, además puede ser la puerta de acceso a otro tipo de malware.

La conexión RDP exitosa desde una IP externa maliciosa indica que las credenciales del equipo víctima fueron comprometidas, posiblemente por el propio Dridex (keylogging) o por otros medios. Una vez con acceso RDP, el atacante tiene la capacidad de moverse lateralmente, intentando comprometer otros equipos, incluyendo el Controlador de Dominio (172.17.8.2), para expandir el control sobre toda la red. El equipo infectado pasa a formar parte de una botnet, pudiendo ser utilizado para otros fines maliciosos.

El empleado del equipo víctima nos confirma que recibió un correo con un documento office de temática relacionada con la empresa con aspecto legítimo que al abrirlo se autoborro, lo que confirma que el vector de entrada fue un correo phishing el cual contenía un adjunto con un documento word que mediante macro descargó y ejecutó el malware.

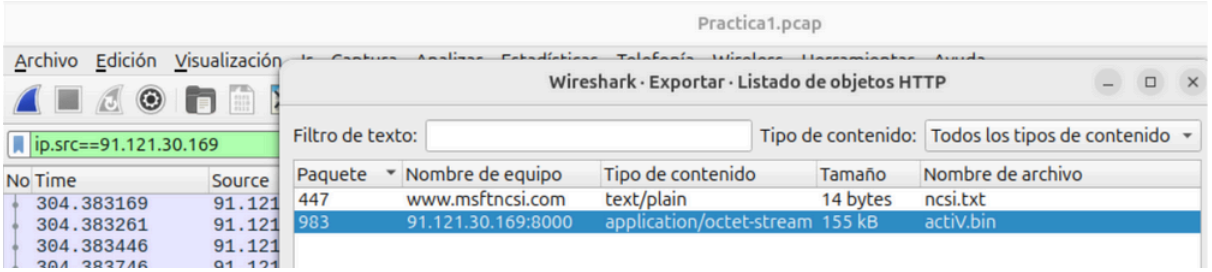
4. Evidencias

4.1 Indicadores de Compromiso (IOCs)

Archivo Malicioso extraído (pcap)

- **Nombre:** actiV.bin
- **Hash (SHA256):** 9f6e3e65aedca997c6445329663bd1d279392a34cfda7d1b56461eb41641fa08
- **Tipo:** Dridex (Troyano Bancario)

```
csubires@csubires-vm:~/Documentos$ sha256sum actiV.bin
9f6e3e65aedca997c6445329663bd1d279392a34cfda7d1b56461eb41641fa08  actiV.bin
```



Obtención del binario descargado mediante el análisis de los paquetes del pcap.

El código del binario está cifrado / ofuscado y no se puede obtener demasiada información de un análisis estático del mismo, pero en los strings se confirma que está compilado y enfocado a atacar sistemas Windows. Cabe destacar que este malware tiene mecanismos anti-debugging lo que dificulta su análisis dinámico.

```
csubires@csubires-vm:~/Documentos$ strings actiV.bin | egrep *.dll
grep: warning: * at start of expression
OLEAUT32.dll
WININET.dll
USER32.dll
GDI32.dll
KERNEL32.dll
urlmon.dll
msvcrt.dll
csubires@csubires-vm:~/Documentos$ file actiV.bin
actiV.bin: PE32 executable (console) Intel 80386, for MS Windows, 6 sections
```

Una búsqueda del hash del archivo en *Virustotal* nos da una información más extensa del código malicioso tal y como nos alertaba el IDS.

www.virustotal.com/gui/file/9f6e3e65aedca997c6445329663bd1d279392a34cfda7d1b56461eb41641

9f6e3e65aedca997c6445329663bd1d279392a34cfda7d1b56461eb41641fa08

56 / 72
Community Score -37

56/72 security vendors flagged this file as malicious

Reanalyze | Similar

9f6e3e65aedca997c6445329663bd1d279392a34cfda7d1b56461eb41641fa08
DirecPLL.DLL

peexe | spreader | runtime-modules | detect-debug-environment | idle | direct-cpu-clock-access | checks-user-input | long-sleeps

Size 152.00 KB
Last Analysis Date 19 days ago

DETECTION | DETAILS | RELATIONS | BEHAVIOR | COMMUNITY 10

Join our Community and enjoy additional community insights and crowdsourced detections, plus an API key to automate checks.

Popular threat label trojan.emotetn/dump
Threat categories trojan | downloader | pua
Family labels emotetn | dump | ursnif

Security vendors' analysis

AhnLab-V3	Trojan/Win32.Agent.R255080	Alibaba	Trojan:Win32/EmotetedCryptc.180910
AliCloud	Trojan:Win/EmotetN.5B5EF6E8	ALYac	Spyware.Banker.Dridex
Arcabit	Dump:Generic.EmotetN.5B5EF6E8	Arctic Wolf	Unsafe
Avast	Win32:Evo-gen [Trj]	AVG	Win32:Evo-gen [Trj]
Avira (no cloud)	HEUR/AGEN.1365915	BitDefender	Dump:Generic.EmotetN.5B5EF6E8

Direcciones IP Maliciosas

- 91.121.30.169 (Servidor de descarga inicial - Puerto 8000)

Analizamos la IP con herramientas online, y vemos que actualmente el servidor que se usó para descargar el binario está offline. Es habitual que se secuestren servidores legítimos para distribuir malware, otras veces solo están accesibles durante el ataque.

Ping Result for IP: 91.121.30.169

Connected To	Response Time	TTL	No of Bytes
Destination Host Unreachable			

Packet Summary

Sent	Received	Loss	Time
5	0	100%	4072 ms

- 192.241.220.183 (Origen del ataque RDP - Puerto 3389)

ww.virustotal.com/gui/file/9f6e3e65aedca997c644532

6e3e65aedca997c6445329663bd1d279392a34cfda7d1b56461eb41641fa08

download.windowsupdate.com	0 / 93	1997-07-22	-
query.prod.cms.rt.microsoft.com	0 / 93	1991-05-02	-
res.public.onecdn.static.microsoft	0 / 93	2023-05-05	MarkMonitor In
www.download.windowsupdate.com	0 / 93	1997-07-22	-
www.microsoft.com	0 / 93	1991-05-02	-

Contacted IP addresses (28)

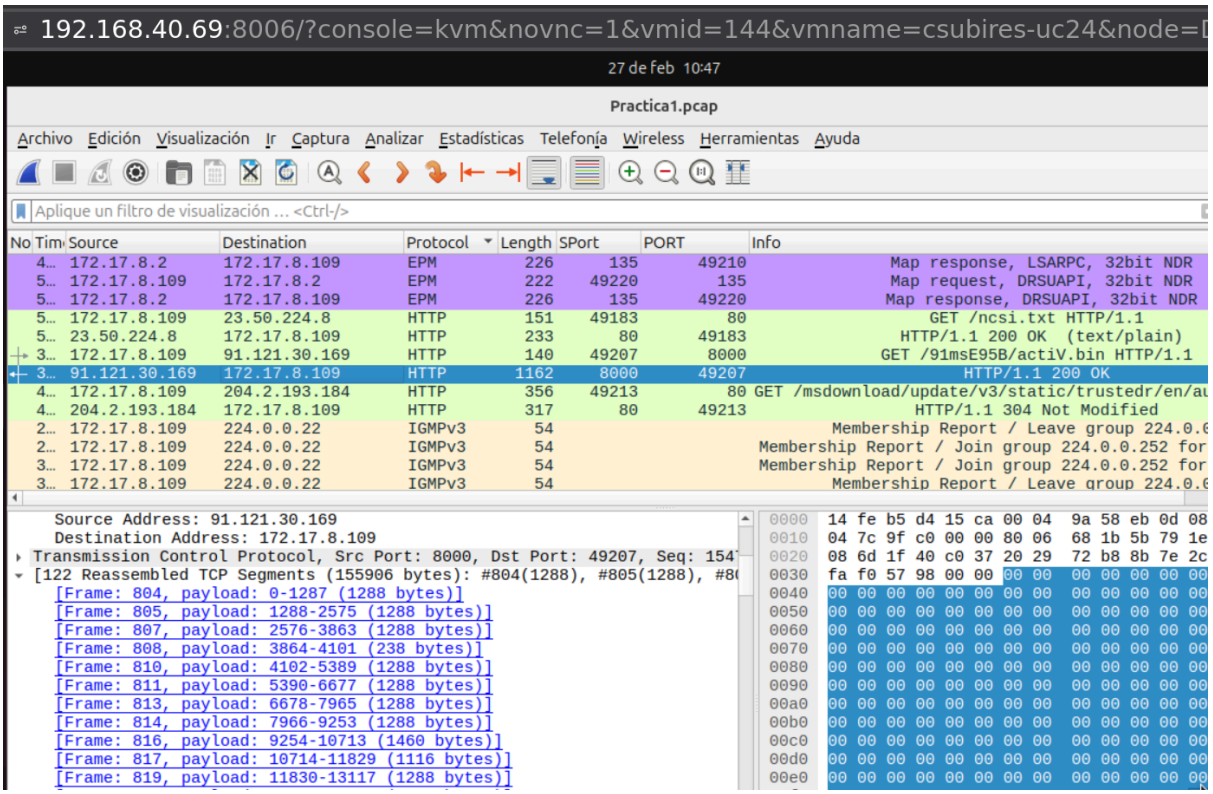
IP	Detections	Autonomous System	Country
104.86.182.43	0 / 93	20940	US
151.101.22.172	0 / 93	54113	US
173.194.195.94	0 / 93	15169	US
185.94.252.27	11 / 93	197890	DE
192.168.0.1	0 / 93	-	-
192.168.0.19	0 / 93	-	-
192.168.0.40	0 / 93	-	-
192.229.211.108	0 / 93	15133	US
192.241.220.183	14 / 93	14061	US

Como se puede observar, el troyano se relaciona con dominios legítimos de Windows asociado con las actualizaciones. Esto puede ser un intento de camuflarse con actividad normal del sistema o generar ruido para dificultar el análisis.

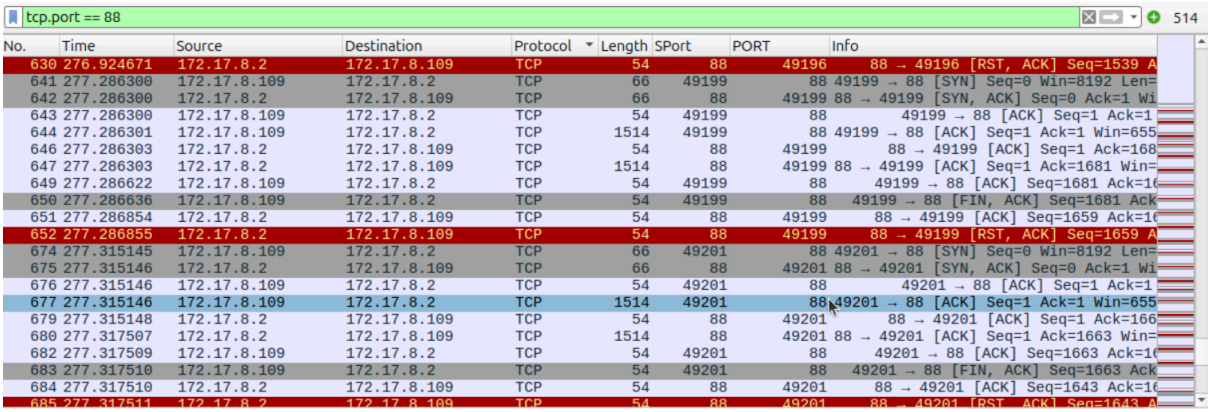
4.2 Indicadores de Ataque (IoAs)

Análisis del volcado de tráfico (pcap)

Entre el tráfico HTTP podemos observar tráfico legítimo al puerto 80 usado por Windows Update y la conexión al puerto remoto 8000 que corresponde con la descarga del malware (*actiV.bin*).



Múltiples intentos de accesos laterales pueden evidenciar un ataque por fuerza bruta para acceder al controlador de dominio usando las credenciales robadas.



Reglas de Alertas IDS

Descarga de binario por puerto HTTP no estándar (8000)

- ET POLICY HTTP Request on **Unusual Port** Possibly Hostile
- ET POLICY **Binary Download** Smaller than 1 MB Likely Hostile
- GPL **SHELLCODE** x86 NOOP
- ET POLICY PE EXE or DLL **Windows file download HTTP**
- ET INFO **Executable Retrieve**d With Minimal HTTP Headers - Potential Second Stage Download

Detección de certificado SSL malicioso asociado a Dridex y conexión RDP desde IP externa no confiable (posible movimiento lateral).

- ET **TROJAN** ABUSE.CH SSL **Blacklist Malicious SSL** certificate detected

5. Acciones realizadas

5.1 Acciones de detección

- Se han analizado los logs del IDS para hacer realizar una primera aproximación del incidente y poder informar al cliente.
- Se ha analizado el volcado de tráfico inmediatamente siguiente a la alerta, identificando los activos involucrados, así como fechas y usuarios.
- Se ha determinado la naturaleza de la amenaza.

5.2 Acciones de contención

- Aislamiento de red: El equipo víctima (172.17.8.109) fue aislado de la red corporativa para prevenir futuros movimientos laterales y la comunicación con el C2.
- Bloqueo preventivo: Se bloquearon a nivel de firewall/perímetro las IPs maliciosas identificadas (91.121.30.169, 192.241.220.183, 216.239.94.252).
- Deshabilitación de cuentas comprometidas.

5.3 Acciones de análisis

- Se han revisado los logs de la máquina afectada.
- Análisis de archivos sospechosos.
- Búsqueda de movimiento lateral.
- Identificación de IOCs e IoAs.
- Preservación de evidencia: Se realizó un volcado automático del tráfico durante los minutos posteriores a la activación de las alertas IDS.

5.4 Acciones de erradicación y recuperación

- Restauración de los sistemas: Una vez recopiladas todas las evidencias pasaremos a realizar una restauración de los sistemas con copias de seguridad limpias y cifradas verificando su hashes.
- Validación de integridad.
- Monitoreo posterior con especial atención a conexiones similares al del equipo afectado.

6. Conclusión del incidente

Se ha confirmado un incidente de seguridad que comprometió un equipo de la red interna con el troyano bancario Dridex. La combinación de la descarga inicial de malware y el posterior acceso por RDP desde una IP maliciosa representa un escenario de alto riesgo, ya que facilitó el movimiento lateral del atacante. Aunque el incidente fue contenido de forma reactiva, la peligrosidad del mismo y la naturaleza del malware obligan a asumir que credenciales y datos confidenciales pudieron haber sido exfiltrados.

El impacto del incidente involucra robo de credenciales, infección de múltiples equipos, compromiso del DC, y pertenencia a botnet. No se descarta el robo de información empresarial, y su impacto en su imagen así como consecuencias legales si se aplica RGPD en este caso.

Hasta que no se hayan analizado en profundidad todos los equipos y analizado si hay más tráfico anómalo, la red queda en cuarentena con servicios mínimos compatibles con el flujo de trabajo de la empresa.

El incidente evidencia la falta de formación de los empleados a la hora de actuar frente a ataques de phishing.

7. Recomendaciones

Inmediatas

- Forzar el cambio de contraseñas de todos los usuarios, especialmente las de administradores de dominio y las que se usaban en la máquina víctima.
- Revisión de GPO para endurecimiento de políticas (hardening).
    - Establecer políticas de mínimos privilegios (los empleados no deben poder ejecutar binarios que no estén en una whitelist).
    - Deshabilitar macros en documentos por GPO en todos los equipos.
- Implementar un cortafuegos a nivel host y configurar reglas estrictas para bloquear tráfico saliente no seguro y a puertos no estándar. No se debe permitir comunicaciones no cifradas o a puertos no convencionales.
- Se debe notificar a las personas afectadas en el caso de que dicho equipo u otros contuviesen datos personales o que afecten a secretos de la empresa.
- Mantener un programa estricto de parcheo y actualización de todos los sistemas.
- El antivirus del sistema Windows debe estar habilitado de forma forzosa en cada sistema con actualizaciones de su base de datos de forma periódica.

A corto plazo

- Segmentar adecuadamente la red internet (VLANs).
- Deshabilitar el acceso RDP de forma externa o protegerlo mediante un servicio de Gateway o VPN + MFA.
- El IDS no es suficiente, hay que implementar EDR, además del XDR.
- Hardening RDP y política de contraseñas robustas.
- Formar a los empleados en la importancia de la seguridad informática y en cómo actuar si detectan alguna anomalía, e implementar una vía de comunicación efectiva con el responsable de seguridad informática.
- Implementar el uso obligatorio de Autenticación Multifactor (MFA) para todos los accesos remotos y cuentas privilegiadas.
- Evaluar y, si procede, notificar a las autoridades competentes (ej. INCIBE) y a los afectados si se confirma fuga de datos personales (en cumplimiento con el RGPD).

A largo plazo

- Activar logging centralizado (SIEM).
- Crear un plan formal de respuesta a incidentes.

Referencias y fuentes de información usadas

Más información sobre el malware:

- https://en.wikipedia.org/wiki/DOS_MZ_executable
- https://www.cronup.com/top-malware-series-dridex/
- https://www.malwarebytes.com/blog/detections/trojan-dridex
- https://www.incibe.es/ciudadania/servicio-antibotnet/info/dridex
- https://darfe.es/ciberwiki/index.php?title=Cridex_(Bugat)
- https://www.cronup.com/top-malware-series-dridex
- https://rarmandoreniery.medium.com/an%C3%A1lisis-malware-bancario-cridex-5c5f8e409bb
- https://www.virustotal.com/gui/file/9f6e3e65aedca997c6445329663bd1d279392a34cfda7d1b56461eb41641fa08
- https://www.welivesecurity.com/la-es/2014/12/03/hooks-api-windows-robo-informacion/

Reglas de alerta del IDS:

- https://helpcenter.trendmicro.com/en-us/article/tmka-19652
- https://docs.rapid7.com/insightidr/suspicious-network-activity/

Ejemplo campaña Dridex:

- https://www.proofpoint.com/us/threat-insight/post/dridex-returns-to-action-for-smaller-more-targeted-attacks

Apéndice

El binario es un ejecutable para Windows cuyo nombre puede variar

File type	Win32 EXE executable windows win32 pe peexe
Magic	PE32 executable (console) Intel 80386, for MS Windows
TrID	Win32 Dynamic Link Library (generic) (25%) | Win16 NE executable (generic) (19.1%) | Win32 Executable (generic) (17.1%) | Win16/32 Executable Delphi generic (7.8%) …
DetectItEasy	PE32 | Linker: Microsoft Linker (11.0) [Console32,console]
Magika	PEBIN
File size	152.00 KB (155648 bytes)

History

Creation Time	2019-01-27 23:39:24 UTC
First Seen In The Wild	2019-01-28 01:39:24 UTC
First Submission	2019-01-28 19:10:35 UTC
Last Submission	2025-12-26 11:12:04 UTC
Last Analysis	2026-02-07 18:57:44 UTC

Names

DirecPLL
DirecPLL.DLL
actiV.bin
sv.exe
3.bin

Resumen de las conexiones realizadas incluidas en el volcado

Wireshark · Load Distribution · Practica1.pcap

Topic / Item	Count	Average	Min Val	Max Val	Rate (ms)	Percent	Burst Rate	Burst Start
HTTP Requests by Server	9				0,0000	100%	0,0100	5,675
HTTP Requests by HTTP Host	9				0,0000	100,00%	0,0100	5,675
239.255.255.250:1900	6				0,0000	66,67%	0,0100	120,875
239.255.255.250	6				0,0000	100,00%	0,0100	120,875
91.121.30.169:8000	1				0,0000	11,11%	0,0100	303,751
91.121.30.169	1				0,0000	100,00%	0,0100	303,751
www.download.windowsupdate.com	1				0,0000	11,11%	0,0100	469,054
204.2.193.184	1				0,0000	100,00%	0,0100	469,054
www.msftncsi.com	1				0,0000	11,11%	0,0100	5,675
23.50.224.8	1				0,0000	100,00%	0,0100	5,675
HTTP Requests by Server Address	9				0,0000	100,00%	0,0100	5,675
204.2.193.184	1				0,0000	11,11%	0,0100	469,054
www.download.windowsupdate.com	1				0,0000	100,00%	0,0100	469,054
23.50.224.8	1				0,0000	11,11%	0,0100	5,675
www.msftncsi.com	1				0,0000	100,00%	0,0100	5,675
239.255.255.250	6				0,0000	66,67%	0,0100	120,875
239.255.255.250:1900	6				0,0000	100,00%	0,0100	120,875
91.121.30.169	1				0,0000	11,11%	0,0100	303,751
91.121.30.169:8000	1				0,0000	100,00%	0,0100	303,751
HTTP Responses by Server Address	3				0,0000	100%	0,0100	5,845
204.2.193.184	1				0,0000	33,33%	0,0100	469,086
OK	1				0,0000	100,00%	0,0100	469,086
23.50.224.8	1				0,0000	33,33%	0,0100	5,845
OK	1				0,0000	100,00%	0,0100	5,845
91.121.30.169	1				0,0000	33,33%	0,0100	304,477
OK	1				0,0000	100,00%	0,0100	304,477

Catálogo de conexiones habituales que realiza el malware

DNS Resolutions

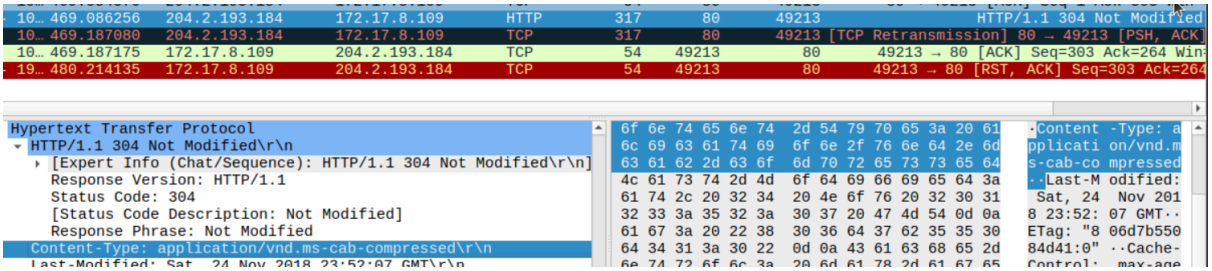
- 185.94.252.27
- 192.241.220.183
- 64.87.26.16
- 69.45.19.252
- wpad
- www.download.windowsupdate.com
  - **Resolved Ips**
    - 72.21.81.240
    - 93.184.221.240
- query.prod.cms.rt.microsoft.com
  - **Resolved Ips**
    - 23.6.103.183
- res.public.onecdn.static.microsoft
  - **Resolved Ips**
    - 23.192.210.9
- www.microsoft.com
  - **Resolved Ips**
    - 23.216.81.152

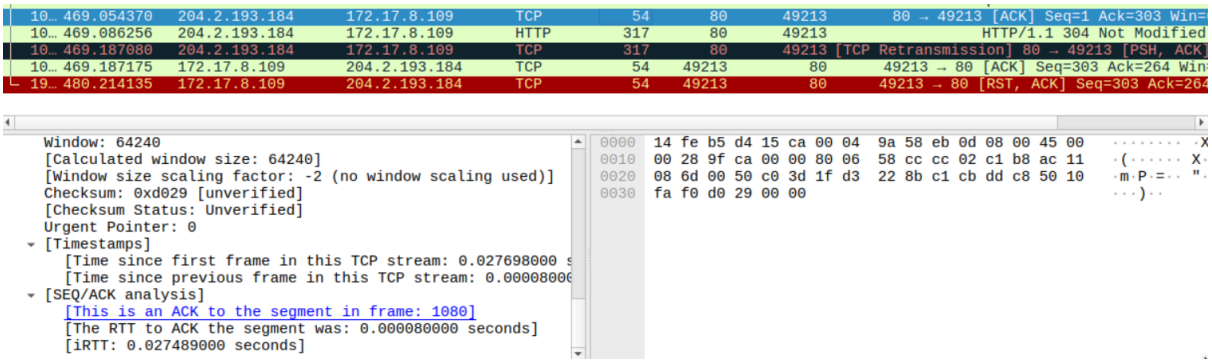
IP Traffic

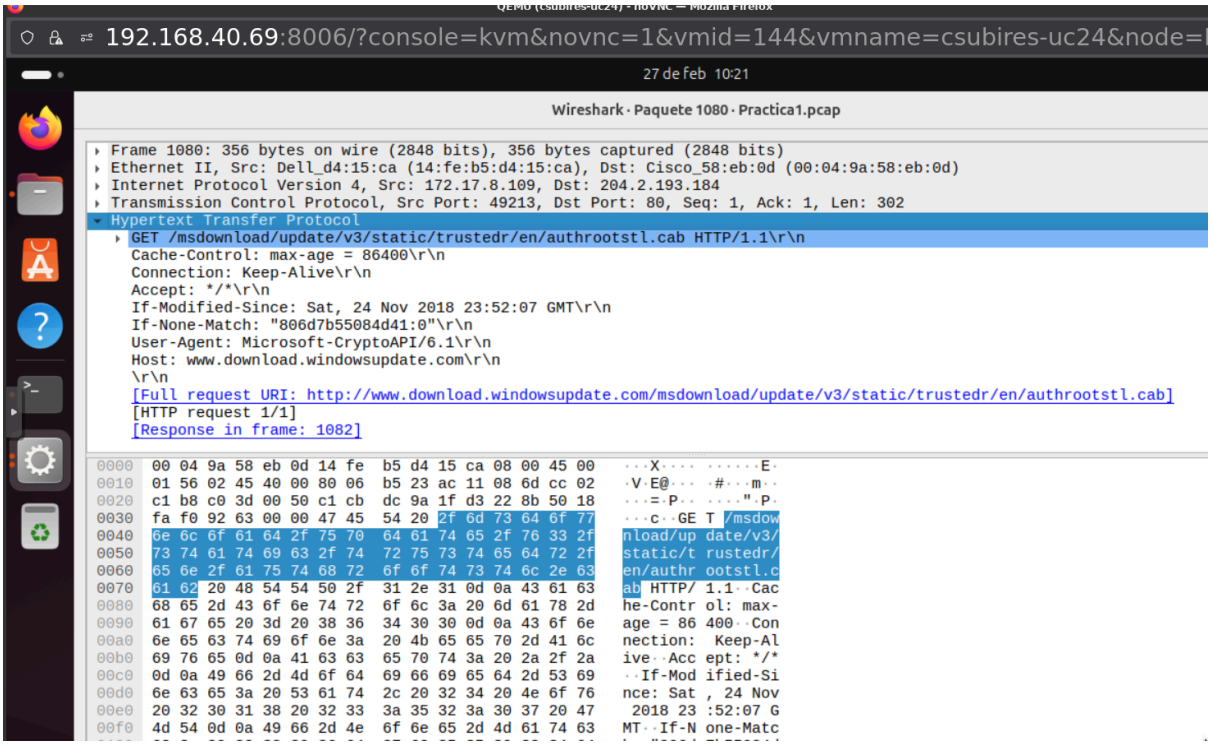
- TCP 173.194.195.94:443
- TCP 192.241.220.183:3389
- TCP 64.87.26.16:443
- TCP 69.45.19.252:1801
- TCP 185.94.252.27:443
- TCP 20.80.129.13:443
- TCP 20.99.133.109:443
- TCP 23.216.147.64:443
- TCP 23.216.147.74:443
- TCP 20.99.184.37:443
- TCP 192.229.211.108:80
- UDP a83f:8110:cce1:d301:10:0:0:0:53
- TCP 104.86.182.43:443
- TCP 20.22.113.133:443
- UDP a83f:8110:1800:0:0:0:0:0:53
- TCP 20.99.186.246:443
- TCP 23.6.103.183:443 (query.prod.cms.rt.microsoft.com)
- TCP 20.99.185.48:443
- UDP 192.168.0.1:137
- UDP a83f:8110:7374:771:cd3:324c:82cf:ee66:53
- UDP 192.168.0.19:137
- TCP 23.216.81.152:80 (www.microsoft.com)
- TCP 151.101.22.172:80
- TCP 23.192.210.9:443 (res.public.onecdn.static.microsoft)
- UDP a83f:8110:0:0:100:0:1800:0:53
- TCP 23.215.176.115:80
- TCP 23.55.140.42:80
- UDP 192.168.0.40:137

Según Virustotal *www.download.windowsupdate.com* es legítimo, aunque si se ha comprometido el DC, también podría tratarse de un DNS Spoofing. Habría que analizar ese .cab que no aparece en el volcado de tráfico.

dns.msftncsi.com -> verifica conexión de updates, también legitimo.







Dridex utilizar certificados para cifrar su comunicación en el C2 lo que nos ha permitido relacionarlo a la IP (`216.239.94.252`) a la cual se accedía por el puerto 443 (HTTPS).

SSL Certificates

Here you can browse all malicious SSL certificates identified by SSLBL. An SSL certificate is identified by a unique *SHA1 hash* (aka *SSL certificate fingerprint*). You can find more information about how to leverage SSLBL to spot botnet C&C traffic here.

Show 50 entries Search: dridex

Listing Date (UTC)	SSL Certificate	Listing Reason	Malware Samples
2020-07-08 14:53:15	550e1cde5c59d03b6f3b9bd3ebfc4af6c7dbec48	Dridex C&C	1
2020-06-23 13:49:21	38ecc7c543c90d25571eae05fbd1948a310761b7	Dridex C&C	4
2020-06-22 18:45:12	6c1cd5f3b4f1a6da97a199397b1bae8226aac7bc	Dridex C&C	1

Conexiones al controlador de dominio

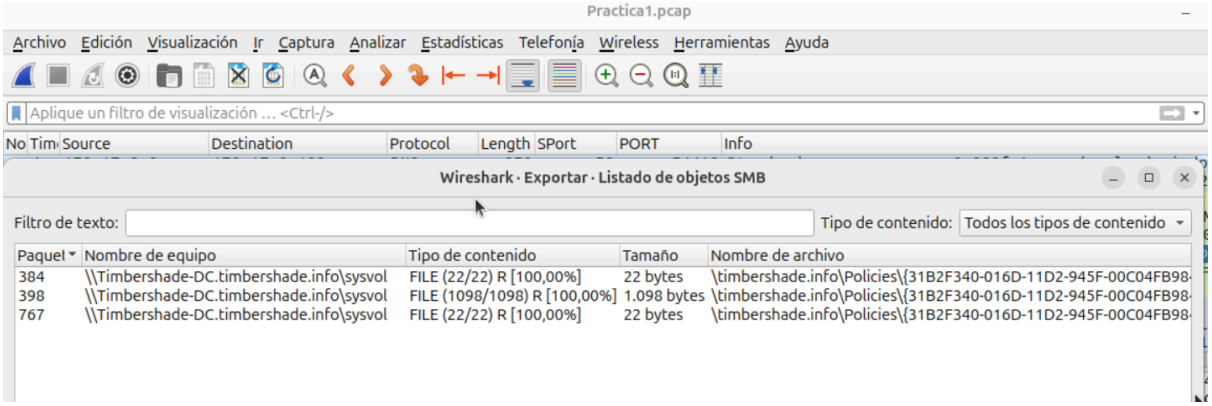
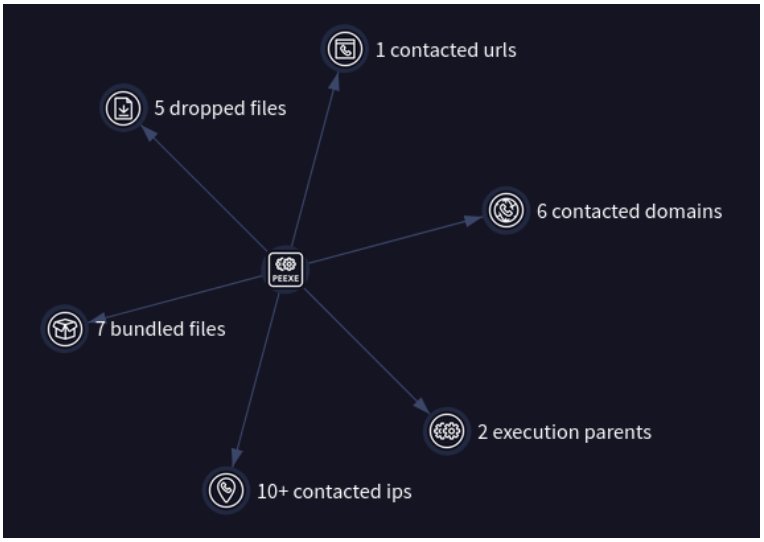



Gráfico resumen del comportamiento de Dridex